SHIELD-AI(TM): Watchlist Report

Components Under Active Monitoring

Security Architecture Practice

August 3, 2026

Abstract
A detailed assessment of the components on the SHIELD-AI watchlist. This is the canonical, always-current watchlist: it is rebuilt and REPLACED by the monthly deep review cycle, which re-scores each component, promotes or demotes items against the decision gates, and updates the edition date. For each component this report covers current state, why it is being watched, realistic attack scenarios, implications for SHIELD-AI controls, and the decision gates that would promote it from the watchlist to a formal control.

SHIELD-AI Watchlist Report

Edition: August 3, 2026 – rebuilt and replaced by each monthly deep review cycle (the repo copy is always the current watchlist).

1. Purpose and Method

The SHIELD-AI monthly deep review (August 3, 2026, v1.4 to v1.5) concluded with six items placed on the framework watchlist: developments that are materially relevant to the security of agentic AI systems but were not yet promoted to formal controls. The review's discipline was deliberate: the framework only adds a control when a gap is confirmed by incident evidence, traceable to named techniques, and implementable at the control level. Everything else – emerging standards, vendor frameworks, evolving attack surfaces, and threat-actor capabilities that cannot yet be mitigated – belongs on the watchlist, where it is actively tracked rather than forgotten.

This report examines each watchlist component in depth. Every section follows the same structure:

- **Current state** – what the component is and where it stands as of the current edition
- **Why it is on the watchlist** – the threat rationale from the deep review
- **Attack scenarios** – concrete ways the component could materialise as an attack class
- **SHIELD-AI implications** – which pillars and controls the component touches, and what a future control would look like
- **Decision gate** – the specific events that would promote this item from watchlist to control

The report closes with a cross-cutting synthesis of the six components, a set of recommendations for the monitoring pipeline, and the promotion calendar for the September 2026 deep review.

2. The Watchlist at a Glance

#	Component	Type	Primary SHIELD-AI linkage	Likelihood	Impact	Trigger to promote
1	IETF A2A protocol standardisation	Standards evolution	IAM-02, IAM-07, TP-09, MIR-02	High	High	Delegation-beyond-two-hops adopted in deployed frameworks
2	Open Secure AI Alliance / NOOA	Industry convergence	All pillars (mapping)	Certain	Medium	SHIELD-AI clients asked to attest against NOOA
3	Time-based supply-chain defences	Defence evolution	DS-07, TP-05, TP-06, GRM-04	High	Medium	Agent publication bypasses quarantine windows

#	Component	Type	Primary SHIELD-AI linkage	Likelihood	Impact	Trigger to promote
4	Edge and on-device agents	Deployment evolution	MS-09, MIR-01, EE-01	High	Medium-High	On-device agent fleet crosses enterprise scale
5	Inbound MCP exposure	Attack surface	TP-10, MS-08	Certain	Critical	Exposed MCP exploitation observed in the wild
6	Adversary-owned autonomous agents	Threat capability	MIR-02, GRM-02	High	Critical	Autonomous campaign compromises a SHIELD-AI-class deployment

3. Component 1: IETF Agent-to-Agent Protocol Standardisation

3.1 Current State

The IETF considered competing agent-to-agent communication protocols at IETF 126 in Vienna in late July 2026, with a standards vote held during the meeting. The candidates in contention are the Agent2Agent (A2A) protocol – an open protocol for agent-to-agent delegation and collaboration backed by a cross-vendor coalition – and the Agent Communication Protocol (ACP), a competing proposal with a different trust and discovery model. Both sit alongside MCP, which is already established as the de facto standard for agent-to-tool interaction but is not, on its own, an agent-to-agent protocol.

The standards process is significant because interoperability standards do not merely standardise interfaces; they standardise trust assumptions. When two agents

from different vendors delegate work to one another, the protocol defines how identity is carried, how consent is propagated, and what guarantees exist about the remote agent's behaviour. These are security decisions wearing interoperability clothing.

3.2 Why It Is on the Watchlist

SHIELD-AI's delegation model is deliberately bounded: IAM-02 restricts delegation to two hops (human to agent to tool), and IAM-07 enforces the delegation chain at the infrastructure layer. The framework's assumption is that cross-agent delegation is an exceptional, high-risk event. A ratified A2A standard with broad framework adoption would normalise multi-hop agent-to-agent delegation inside and between organisations, directly challenging that assumption.

Three watch-relevant properties of the emerging standard were flagged in the deep review:

- **Identity propagation.** How does the standard carry the originating identity across delegation hops? If the remote agent re-authenticates as itself rather than carrying the delegated identity, every downstream control loses its audit trail.
- **Consent semantics.** Does a human approval at hop one bind to actions taken at hop three? If not, human oversight (IAM-03) is structurally defeated by design.
- **Trust establishment.** What tells an agent that the agent it is about to delegate to is trustworthy? In the absence of a defined trust model, protocols default to "anyone who speaks the protocol."

3.3 Attack Scenarios

Scenario A: Delegation-chain amplification. An attacker compromises a low-value agent in organisation X and, through A2A, delegates a prompt-injection payload to a high-value agent in organisation Y that has accepted an A2A trust relationship. The payload executes with organisation Y's data access. The current two-hop bound is simply not present in the protocol's default trust model.

Scenario B: Prompt-injection propagation. An agent that has absorbed attacker-injected instructions passes those instructions – or the poisoned reasoning trace – to peer agents via A2A messages. Each peer treats the message as a legitimate request. The attack propagates agent to agent, similar to the swarm-campaign pattern already flagged in MIR-02, but using a sanctioned inter-agent channel.

Scenario C: Phantom delegation. An attacker registers a malicious agent that responds to A2A discovery requests. Legitimate agents delegate subtasks to it, exfiltrating data through the “legitimate” protocol channel – a mirror of the exposed-MCP problem (Component 5) at the agent layer.

3.4 SHIELD-AI Implications

Control	Implication
IAM-02 (scope-bound delegation)	A2A delegation must be treated as a tool invocation for scoping purposes; peer agents are registered principals, not free delegates
IAM-07 (delegation chain enforcement)	The two-hop bound must extend across protocol boundaries; A2A messages must carry the full delegation context or be denied
TP-09 (explicit tool registration)	Peer agents accessed over A2A must enter the registry with the same vetting as tools
MIR-02 (anomaly detection)	Inter-agent traffic is a new telemetry surface; baselines must include A2A message volume and delegation depth
MS-08 (MCP security)	A2A and MCP are converging surfaces; a single trust policy should govern both

Likely future control shape: an extension to IAM-07 (“cross-protocol delegation bound”) mandating that any delegation that leaves the local agent platform carries a verifiable originating-identity and consent chain, with a hard default of one protocol hop unless explicitly registered.

3.5 Decision Gate

Promote to a formal control when any of the following occur:

1. A major agent framework (LangGraph, CrewAI, Semantic Kernel, or an equivalent) ships A2A delegation enabled by default
2. The ratified standard omits mandatory identity propagation and the omission is adopted in production implementations
3. A confirmed incident uses inter-agent delegation as an attack vector

3.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- Adoption announcements from major agent frameworks (LangGraph, CrewAI, Semantic Kernel, AutoGen, OpenAI Agents SDK) regarding A2A or ACP support
- IETF working-group outcomes following the IETF 126 vote: charter, draft milestones, and especially the security-considerations sections
- Enterprise deployment reports of cross-vendor agent delegation
- A2A-related CVEs or security research describing protocol-level trust flaws
- Any documented incident using inter-agent delegation as an attack vector

---

4. Component 2: The Open Secure AI Alliance and NOOA Framework

4.1 Current State

On July 27, 2026, NVIDIA and 36 partners launched the Open Secure AI Alliance, a 37-member industry body for AI safety and security, and open-sourced the NOOA framework as the alliance's reference agent-security framework. Coverage of the launch noted three notable absences among the major AI labs. The Linux Foundation contributed a companion statement framing open models and open weights as foundational to secure AI.

This is the most significant industry-convergence event since the v1.4 cycle mapped the Five Eyes "Careful Adoption of Agentic AI Services" guidance. For the first time, a hardware vendor is convening the agent-security agenda rather than a model lab or a security vendor.

4.2 Why It Is on the Watchlist

The deep review flagged industry convergence for a specific reason: framework proliferation creates attestation pressure. Enterprise clients of SHIELD-AI will increasingly be asked – by vendors, insurers, and regulators – to attest against multiple frameworks: NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, the EU AI Act's obligations, and now an alliance framework with a hardware vendor's

distribution channel behind it. If NOOA and SHIELD-AI diverge in control language, clients face duplicated assurance work and conflicting guidance.

The watchlist question is not “is NOOA a threat?” but “what does convergence mean for SHIELD-AI’s mapping story?” SHIELD-AI already maintains a regulatory mapping layer (GRM-05); a vendor-framework mapping is a natural extension. The risk is divergence on substance: if NOOA’s sandboxing guidance contradicts EE-01..EE-08, or its identity model contradicts IAM-01..IAM-09, clients get contradictory mandates.

4.3 Implications for SHIELD-AI

- **Mapping, not merging.** SHIELD-AI’s value is its threat-informed, incident-driven control set. The correct response is a maintained mapping table (SHIELD-AI control to NOOA control), not adopting NOOA’s structure wholesale.
- **Validation opportunity.** An alliance framework is a chance to validate SHIELD-AI’s incident lineage publicly: every control in v1.5 traces to a named incident or CVE. If NOOA’s controls map cleanly onto SHIELD-AI’s 55, the framework’s coverage claim is strengthened; where NOOA covers something SHIELD-AI does not, that is a genuine signal to evaluate.
- **Differentiation risk.** If NOOA’s framework is permissive on execution-environment isolation, SHIELD-AI’s EE pillar – its most incident-validated contribution – becomes a differentiator to lead with in client conversations.

4.4 Decision Gate

Promote from watchlist to an active work item (mapping layer extension, not a control) when:

1. NOOA control definitions are published in sufficient detail to map (expected within one to two quarters of the July launch)
2. A SHIELD-AI client or prospect explicitly asks for a NOOA crosswalk
3. NOOA guidance contradicts a SHIELD-AI control in a way that would force a client choice

4.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- Publication of NOOA control definitions or reference implementations

- Alliance membership changes (additions and notable absences) and direction shifts
- Guidance conflicts with SHIELD-AI EE or IAM controls, such as a materially different sandboxing or identity model
- Client or prospect requests for a NOOA crosswalk
- Regulatory or insurance adoption of NOOA as an attestation baseline

---

5. Component 3: Time-Based Supply-Chain Defences

5.1 Current State

The supply-chain attack surface continues to expand. The TrapDoor campaign (May 2026) compromised 34 packages across npm, PyPI, and CratesIO simultaneously, using credential-stealing malware to harvest developer credentials and actively exploit them to push further malicious packages. TeamPCP (March 2026) demonstrated the “weaponised protector” pattern: attacking security-infrastructure packages so that downstream security tooling itself becomes the distribution mechanism. These join the established typosquatting and dependency-confusion classes.

In response, the ecosystem is experimenting with **time-based defences**: publication quarantine windows (new packages or new publishers are not immediately installable at scale), token-freshness requirements (publication credentials must be recent, defeating long-lived stolen tokens), and time-correlation analysis (packages published immediately after a credential leak are treated as suspect). These defences are promising but unevenly deployed, and their interaction with automated pipelines is poorly understood.

5.2 Why It Is on the Watchlist

Two deep-review threads converge here. First, **DS-07** (added in v1.5) makes SHIELD-AI’s agents producers of supply-chain artifacts: agent-authored packages, images, and configurations now enter the same vetting pipeline as third-party artifacts. Second, the v1.5 incident set (INC-19, Anthropic) proved a model can

publish malicious code that real systems execute. Time-based defences are the ecosystem's emerging answer to exactly this class – and SHIELD-AI needs to know whether its DS-07 publication pipeline is compatible with them.

The specific watch question: can an agent's publication flow bypass time-based defences? If an agent publishes with a fresh, valid credential (because the agent's credentials are, by design, short-lived and freshly minted – per IAM-08 and DS-07), then a time-based defence keyed on token freshness sees a legitimate signal. An attacker who compromises an agent's publication path inherits that fresh credential. Time-based defences tuned for human attackers may be structurally blind to agent publishers.

5.3 Attack Scenarios

Scenario A: Fresh-credential publication. An agent with a compromised reasoning chain publishes a malicious package using its legitimately fresh publication token. Quarantine windows expire; the package reaches consumers. The token's freshness, which the ecosystem treats as a trust signal, is exactly what makes the agent's publication look clean.

Scenario B: Quarantine-window abuse. An attacker who controls an agent schedules publication during a period of low ecosystem scrutiny, or publishes a benign package to establish a clean publication history, then ships the payload once the history is established – the "slow build" attack, now automated at agent speed.

Scenario C: Backdated provenance. Agent-originated artifacts with forged or misleading provenance timestamps defeat time-correlation analysis.

5.4 SHIELD-AI Implications

Control	Implication
DS-07 (artifact publication control)	The vetting pipeline must incorporate time-based signals: quarantine, freshness correlation, and publication-history scoring for agent-originated artifacts
TP-05 (pipeline integrity)	CI/CD and agent pipelines must not exempt agent publications from quarantine on the grounds that credentials are fresh
TP-06 (dependency scanning)	

Control	Implication
	The HIGH-RISK dependency class must include “new publisher” and “recently quarantined” signals
GRM-04 (third-party AI risk)	Ecosystem-level defence adoption becomes part of vendor assurance: does the model/tool provider enforce token freshness and publication vetting?

Likely future control shape: an extension to DS-07 (“time-based publication vetting”) requiring agent-originated artifacts to pass the same time-based gates as third-party artifacts, with publication-history scoring before distribution.

5.5 Decision Gate

Promote when any of the following occur:

1. A confirmed incident shows an agent-originated artifact bypassing time-based defences (the fresh-credential scenario)
2. PyPI, npm, or GitHub makes quarantine windows mandatory for new publishers, requiring SHIELD-AI guidance for agent publishers
3. A SHIELD-AI client’s agent publication pipeline is blocked or delayed by time-based defences, creating an operational conflict

5.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- TrapDoor-class campaign follow-ups and new cross-ecosystem credential-theft campaigns
- PyPI, npm, and GitHub policy changes: mandatory quarantine windows, token-freshness enforcement, new-publisher restrictions
- Agent-originated package publication incidents in any ecosystem
- Research on time-based defence bypass: fresh-credential publication, slow-build history laundering, backdated provenance
- DS-07 operational experience: how client publication pipelines interact with quarantine windows in practice

---

6. Component 4: Edge and On-Device Agents

6.1 Current State

On-device AI capability is scaling rapidly. Google's Gemma 4 12B release (June 2026) brought on-device agent-class models to consumer hardware, and on-device AI is moving into frontline operations in retail, logistics, and manufacturing (July 2026). The security implications were already demonstrated in the v1.5 cycle: INC-25 showed open-source Android agents hijacked via invisible on-screen text – an imperceptible-content attack against the screen-reading input channel of an on-device agent.

The deep review placed on-device agents on the watchlist as an extension of MS-09's scope: the perception-fidelity control was written for text-input channels, and on-device agents add OCR, screen capture, and sensor channels that the control does not yet explicitly cover.

6.2 Why It Is on the Watchlist

Three properties distinguish on-device agents from server-side agents, each eroding a SHIELD-AI assumption:

- **No server-side visibility.** MIR-01's activity logging assumes a telemetry pipeline exists. An on-device agent with no egress telemetry is invisible to the SIEM, to anomaly detection, and to incident response.
- **Perception channels are richer and less trusted.** A server-side agent reads text content; an on-device agent reads rendered screens, OCR output, notifications, and sensor data. Each channel is a new injection surface, and the human's screen is simultaneously the agent's input and the attacker's payload delivery mechanism (INC-25).
- **The device is the sandbox.** EE-01's boundary enforcement assumes a container or VM under platform control. On-device agents run inside a consumer OS process with device-level privilege boundaries, and the framework has no guidance for that environment.

6.3 Attack Scenarios

Scenario A: Screen-channel hijack (extending INC-25). A web page or notification renders imperceptible text that the on-device agent's OCR pipeline reads as instructions. The agent invokes tools with device-level permissions the user believes are protected. The user sees nothing because the content is invisible to human vision.

Scenario B: Telemetry-blind compromise. A compromised on-device agent exfiltrates data over the device's legitimate network connections. No SHIELD-AI monitoring component exists on the device, so the exfiltration is undetectable until it surfaces in a downstream system.

Scenario C: Model and context theft. On-device models and their fine-tuning context (including enterprise RAG context cached on the device) are extracted from a lost or compromised device. DS-02's inference-data protection has no on-device counterpart.

6.4 SHIELD-AI Implications

Control	Implication
MS-09 (perception-fidelity)	Scope extension to OCR, screen-capture, and notification channels; rendering-fidelity snapshots must cover what the agent perceives, not what the human is shown
MIR-01 (activity logging)	On-device agents require a telemetry contract: either egress telemetry or a documented logging gap accepted by risk owners
EE-01 (boundary enforcement)	Device-level isolation guidance: app sandboxing, permission minimisation, and hardware-backed attestation for on-device runtimes
DS-02 (inference data protection)	On-device model and context encryption, plus remote-wipe and revocation paths for enterprise context

Likely future control shape: an MS-09 extension ("perception-channel coverage") plus a new deployment-context note covering on-device agents in the EE pillar, mirroring the existing deployment-context awareness guidance.

6.5 Decision Gate

Promote when any of the following occur:

1. An enterprise-class on-device agent framework ships with tool-invocation privileges (not just chat)
2. A second confirmed incident uses a screen or OCR channel for agent hijack (INC-25 becomes a pattern, not an outlier)
3. A SHIELD-AI client deploys on-device agents in a regulated workflow with a documented telemetry gap

6.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- On-device agent framework security disclosures across Android, iOS, and vendor SDKs
- Enterprise on-device agent deployments that carry tool-invocation privileges rather than chat-only capabilities
- A second INC-25-class incident using a screen, OCR, or notification channel for agent hijack
- On-device model extraction or context-theft incidents
- Regulatory developments on consumer and edge AI security, including device attestation mandates

---

7. Component 5: Inbound MCP Exposure

7.1 Current State

MCP is the de facto standard for agent-to-tool interaction, and its security posture is under sustained pressure. In April 2026, OX Security documented a systemic, “by design” vulnerability at the core of MCP, estimating 200,000 servers at risk and 150 million package downloads exposed to AI supply-chain attacks. Wiz research (July 28, 2026) catalogued internet-exposed MCP servers being discovered and targeted directly – without any agent in the loop – and Metasploit Framework 6.5 shipped an MCP server, normalising attacker-facing agent-tool interfaces in offensive tooling.

The v1.5 deep review treated the inbound MCP surface as the strongest watchlist-to-control candidate: TP-10 (agent platform inbound control-plane protection) already covers the class, and INC-24 (Metasploit/Wiz) is documented as coverage evidence. The item remains on the watchlist because TP-10's coverage is partial: it protects the agent platform's own listeners, but not the broader ecosystem problem of MCP servers deployed as standalone services.

7.2 Why It Is on the Watchlist

The watch rationale is the gap between what TP-10 controls and what the ecosystem exposes:

- **TP-10 protects the platform.** It governs the listeners on an agent platform or agent host. It does not govern an MCP server deployed as a standalone microservice, an AI gateway's MCP endpoint, or a third-party MCP server an organisation has adopted.
- **Exposure is discovery-driven.** Wiz found exposed servers by scanning; attackers do the same. An exposed MCP server is a tool-invocation surface with no agent required – a direct API for anyone who finds it.
- **The tool supply chain is also inbound.** OX Security's finding is that MCP's design trusts tool definitions and server responses; poisoning the tool definition chain (via compromised registries or malicious servers) attacks every agent connected to it.

7.3 Attack Scenarios

Scenario A: Direct server compromise. An internet-exposed MCP server is discovered and invoked directly by an attacker, who uses its tools (which may include file, shell, or database capabilities) without any agent mediation. The organisation's MCP tool inventory becomes the attacker's tool inventory.

Scenario B: Tool-definition poisoning. An attacker controls a package or server in the MCP tool supply chain and ships a tool definition whose schema or instructions redirect agent behaviour – the OX Security "mother of all AI supply chains" scenario, now with a shorter fuse because agents auto-load tool definitions at connection time (the Kiro pattern, INC-20).

Scenario C: Gateway MCP exposure. An AI gateway exposes an MCP endpoint for client agents; the endpoint inherits the gateway's credentials and tool access.

CSWSH-style attacks (the OpenClaw pattern, INC-21) target the endpoint's WebSocket surface.

7.4 SHIELD-AI Implications

Control	Implication
TP-10 (inbound control-plane protection)	Scope extension: MCP servers deployed as standalone services and gateway MCP endpoints must be governed by the same default-deny binding policy
MS-08 (MCP security)	Tool-definition integrity at connection time: signed tool definitions, schema validation, and no auto-load of unregistered servers
TP-09 (explicit tool registration)	MCP servers consumed by agents must be registered, vetted, and versioned like any other tool
MIR-02 (anomaly detection)	Inbound MCP connection attempts (especially from unexpected sources) must be a monitored signal

Likely future control shape: a TP-10 extension ("standalone MCP server governance") covering discovery, exposure scanning, and default-deny binding for MCP services outside the agent platform.

7.5 Decision Gate

Promote when any of the following occur:

1. A confirmed in-the-wild compromise of an exposed MCP server (not research demonstration)
2. OX Security's systemic flaw is exploited at scale (a documented MCP supply-chain attack)
3. A major AI gateway ships MCP endpoints enabled by default

7.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- In-the-wild exposed-MCP compromise reports, as opposed to research demonstrations

- OX Security follow-ups or public exploit development for the systemic MCP flaw
- AI gateway MCP endpoint defaults, especially enabled-by-default announcements
- Metasploit-class offensive tooling adding MCP surfaces
- MCP registry and tool-definition supply-chain incidents

---

8. Component 6: Adversary-Owned Autonomous Agents

8.1 Current State

The capability became operational in July 2026. Unit 42 documented a Chinese-speaking threat actor operating the open-source Hermes agent framework with DeepSeek as the reasoning engine in “Yolo” mode, controlled over Telegram, integrated with the FOFA asset-search engine and custom offensive skills. In a recovered session, the agent scanned 84 internet-exposed Langflow servers for a vulnerability and attempted exploitation autonomously after a single operator task. The campaign did not succeed, but it confirmed an end-to-end autonomous offensive capability. Since then, threat-intelligence reporting (Security Affairs, July 31; Help Net Security, August 3) indicates cybercriminals are actively adopting autonomous offensive agents, and analysis of DeepSeek as the attack engine points to its comparatively weak guardrails as the reason it is the model of choice.

The v1.5 deep review designated this G19: a High-severity gap that cannot yet be mitigated by a control, because an organisation cannot impose controls on an adversary’s agent. What an organisation can do is detect, respond to, and automate defence against machine-speed adversaries.

8.2 Why It Is on the Watchlist

G19 is qualitatively different from every other gap in the ledger. Every prior gap described something SHIELD-AI could control: a sandbox, a config file, a tool registry. G19 describes an adversary’s capability – autonomous discovery, autonomous exploitation, self-propagating campaigns – against which defensive controls are inherently asymmetric. The watchlist status reflects that asymmetry

rather than a lesser severity: the impact is Critical, but the mitigation is detection and response, not prevention.

Two properties drive the watch rationale:

- **Machine speed.** A human adversary plans, types, and executes at human speed. An autonomous agent does not. Defences built on human-paced response times (24-hour SOC triage, weekly scans) are structurally outpaced.
- **Low operator cost.** The Unit 42 session showed a single operator task producing hours of autonomous activity. The cost asymmetry means many adversaries will adopt the capability; it will stop being a state-actor niche.

8.3 Attack Scenarios

Scenario A: Mass autonomous discovery. An adversary agent scans for exposed agent platforms, Langflow-class applications, and MCP servers (per Component 5) at machine speed, triaging thousands of targets per hour. The scanning itself is cheap; the marginal cost per target approaches zero.

Scenario B: Autonomous exploitation chain. An adversary agent discovers a target, validates a vulnerability, builds an exploit from public proof-of-concept, and pivots – all without operator involvement. Defensive teams face an attacker who never sleeps, never makes a mistake under fatigue, and never stops to think.

Scenario C: Agent-versus-agent defence. The only speed-matched defence is defensive automation: autonomous defensive agents that patch, quarantine, and respond. This is a significant operational shift for SOCs, and the framework's GRM-02 kill-switch becomes the safety mechanism for the defence itself.

8.4 SHIELD-AI Implications

Control	Implication
MIR-02 (anomaly detection)	Adversary-owned agent detection: patterns of machine-speed scanning, FOFA-class discovery, and autonomous exploitation attempts
MIR-04 (IR playbooks)	Agent-speed incident response: automated containment and rollback playbooks triggered without human-in-the-loop latency

Control	Implication
GRM-02 (AI risk register / kill-switch)	The kill-switch is also a defence for defensive automation: autonomous defensive agents must have a tested, human-invokable stop
GRM-04 (third-party AI risk)	Model-provider guardrail posture becomes a supply-chain risk factor: models with weak guardrails are the attack engine of choice

No control is proposed for G19 itself. The framework's position, as recorded in the deep review, is that prevention is not achievable against an adversary's agent; the mitigation is detection, automated response, and threat-intelligence-driven hardening of the surfaces the adversary targets (which is why G14-G17 controls matter).

8.5 Decision Gate

Promote from watchlist to an active defence-work item when any of the following occur:

1. A confirmed autonomous-agent campaign compromises a production system (the Unit 42 campaign remains unconfirmed in outcome)
2. Autonomous offensive agents become commercially available (as-a-service), collapsing the capability cost further
3. A SHIELD-AI client reports autonomous scanning against its external surface

8.6 Monitoring Signals

The weekly and monthly cycles should track the following for this component:

- Autonomous campaign outcomes: the Unit 42 campaign and its successors, with confirmed-compromise status
- As-a-service autonomous offensive agent offerings that collapse the capability cost further
- Reports of autonomous scanning against SHIELD-AI-class deployments
- Model-guardrail research affecting the "attack engine of choice" calculus
- Defensive-automation incidents: autonomous defensive agents misbehaving, which informs the GRM-02 kill-switch requirements for agent-speed defence

---

9. Cross-Cutting Synthesis

Across the six components, four threads recur. They are worth stating explicitly because they define where agentic security is heading between the August 2026 deep review and the September cycle.

Thread 1: The inbound surface is the new frontier. Components 5 and 6 converge on the same conclusion: the attacker is no longer trying to make an agent misbehave outbound; they are connecting in to surfaces the agent platform exposes, or deploying their own agents to do so. TP-10's default-deny binding policy is the framework's most important recent addition precisely because it addresses the inbound direction. The watchlist keeps returning to it.

Thread 2: Machine speed invalidates human-paced response. Components 6, and to a lesser extent 1 and 5, all assume defenders operate at human speed. Every control that relies on human review, human triage, or human approval must be examined for whether it can be outpaced. This does not mean removing humans; it means the framework's monitoring and response controls (MIR-02, MIR-04, GRM-02) must specify automated first-response layers with humans in oversight, not in the critical path.

Thread 3: The agent is a producer, not just a consumer. Components 3 and the v1.5 incident set established that agents publish artifacts, credentials, and services. DS-07 was the response; the watchlist extends the principle to time-based defences (Component 3) and to the protocol layer (Component 1), where agents will publish delegation requests and trust relationships.

Thread 4: Standards and alliances will set the agenda. Components 1 and 2 are both standardisation events. Whether it is IETF protocol trust models or an alliance's reference framework, external bodies are increasingly defining the security language clients will be asked to speak. SHIELD-AI's response is a maintained mapping layer (GRM-05) and a threat-informed control set that can justify its positions against any external framework.

9.1 Interaction Matrix

The six components are not independent. Their interactions define the attack chains most likely to materialise, and the interaction matrix below is the reference used by the monitoring pipeline when correlating signals across components:

Interaction	Shared attack chain
A2A (1) x adversary agents (6)	Protocol-borne delegation as a propagation channel for autonomous campaigns: an adversary agent delegates poisoned subtasks to trusted peer agents over a ratified protocol
Inbound MCP (5) x adversary agents (6)	Autonomous scanning targets exposed MCP servers directly; the attacker's tool inventory and the organisation's tool inventory become the same inventory
Time-based defences (3) x agent publication (DS-07)	Fresh-credential publication bypasses quarantine; the agent-as-producer defeats time signals designed for human publishers
Edge/on-device (4) x inbound MCP (5)	On-device agents connecting to MCP servers inherit the server's tool surface, while device telemetry gaps hide the connection from MIR-01
A2A (1) x inbound MCP (5)	Converged trust model: delegation and tool channels governed by a single policy, which is the direction already implied by MS-08's scope
NOOA (2) x all components	The mapping layer absorbs external framework language; divergence on any component's control direction forces a client choice

The two highest-consequence interactions are the first two. Both combine a ratified or normalised channel (A2A, MCP) with a machine-speed actor (Component 6). The monitoring pipeline should treat a signal in both cells of an interaction as a promotion-grade event, not a routine coverage note.

---

10. Recommendations

10.1 For the Monitoring Pipeline (immediate, Q3 2026)

The weekly sandbox-escape watch cycle should carry the following tracking hooks, one per component:

Component	Weekly tracking hook
IETF A2A	Status of the IETF 126 standardisation outcome and framework adoption announcements
Open Secure AI Alliance / NOOA	Publication of NOOA control definitions; membership changes; guidance contradictions with EE/IAM controls
Time-based supply chains	TrapDoor-class campaigns; quarantine-window policy changes at PyPI/npm/GitHub; agent-publication incidents
Edge/on-device agents	On-device agent framework security disclosures; enterprise deployments of tool-invoking on-device agents
Inbound MCP exposure	In-the-wild exposed-MCP compromises; gateway MCP endpoint defaults; OX Security follow-ups
Adversary-owned agents	Autonomous campaign outcomes; as-a-service offerings; scanning reports against SHIELD-AI-class deployments

10.2 For the September 2026 Deep Review

- **Promotion candidates (strongest first):** Inbound MCP exposure (Component 5) is the closest to promotion – a TP-10 scope extension is well defined and the attack surface is documented. Adversary-owned agents (Component 6) moves from watchlist to active defence-work item only on incident evidence. IETF A2A (Component 1) is likely to be promoted to a control once framework adoption is confirmed.
- **Mapping work:** begin the NOOA-to-SHIELD-AI crosswalk as a GRM-05 mapping extension once NOOA definitions are available.
- **MS-09 scope:** draft the perception-channel extension (OCR, screen capture, notifications) as a defined-but-unratified control, ready to ratify on the second on-device incident.

10.3 Longer-Term Positioning

The four threads in Section 9 should inform the framework's v1.6 direction regardless of individual promotions: an explicit inbound-surface treatment in the reference architecture, automated-first response layers in the monitoring pillar, producer-side controls in the data and pipeline pillars, and a maintained external-framework

mapping layer. None of these require the watchlist items to resolve first; they are evolutionary directions the watchlist is already pointing at.

---

11. Assessment Criteria and Scoring Method

This section records how watchlist items are scored, why promotion discipline matters, and how the watchlist itself is governed between deep reviews. It is written so the September 2026 deep review can apply the same method without reinterpretation.

11.1 Scoring

Each watchlist component carries two scores, assigned at the deep review that placed it on the watchlist and re-scored monthly:

Score	Definition
Likelihood: Certain	The development has occurred or is confirmed in progress (e.g., an alliance has launched, a protocol vote has been scheduled)
Likelihood: High	Strong evidence the development will materialise within the quarter (e.g., a vulnerability class with public exploit research)
Likelihood: Medium	Plausible but unconfirmed trajectory
Impact: Critical	A materialised development would defeat an existing control or enable a class of compromise with systemic reach
Impact: High	A materialised development would require control extension or would significantly raise the cost of assurance
Impact: Medium	A materialised development affects operational posture without defeating controls

Scores are re-examined each month against the monitoring signals in Sections 3.6 through 8.6. A component whose scores change by a full band (e.g., High to Critical impact) is flagged for immediate review rather than waiting for the monthly cycle.

11.2 Evidence Standard

Watchlist entries require named sources (the Appendix A discipline). Promotion to a control requires more than plausibility; it requires one of:

- **Incident evidence** – a documented attack using the technique, with a named incident or CVE
- **Adoption evidence** – the capability or surface is deployed at scale in the target environment (e.g., a framework ships a feature enabled by default)
- **Capability evidence** – for adversary capabilities that cannot be controlled (Component 6), a demonstrated operational use rather than research demonstration

This is the same evidence standard the framework has applied since v1.1: the C2 specificity criterion from the review methodology requires every gap to trace to a named incident. The watchlist exists precisely to hold items that do not yet meet the standard while they are being tracked.

11.3 Promotion and Demotion Discipline

- **Promotion** happens at a deep review, except when an interaction-matrix event (Section 9.1) fires; those are promotion-grade immediately.
- **Demotion** happens when a component's trajectory stalls for two consecutive cycles without evidence movement. Demoted components are either archived with a written rationale or re-scoped. A component never lingers silently on the watchlist.
- **Ledger discipline.** Every re-score, promotion, and demotion is recorded in the coverage ledger alongside the incident lineage, so the watchlist's own history is auditable in the same way the framework's is.

11.4 Relationship to the Framework

The watchlist is deliberately not part of the framework document. The framework's 55 controls are ratified, incident-validated requirements; the watchlist is a forward-looking instrument. Mixing the two would dilute both – controls would gain unvalidated entries, and watchlist items would lose their explicit "not yet a control" status. This separation is itself a governance decision, recorded here so future maintainers do not collapse the distinction.

Appendix A: Sources Referenced

- Tech Times, “AI Agent Protocol Standard Vote Arrives Thursday at IETF 126 in Vienna” (July 22, 2026) and “Competing AI Agent Protocols Face IETF Standards Scrutiny at Vienna Meeting” (July 18, 2026)
- The Hacker News, “NVIDIA Forms 37-Member Open Secure AI Alliance and Open-Sources NOOA Framework” (July 27, 2026); NVIDIA Blog, “Industry Leaders Unite in Open Secure AI Alliance for AI Safety and Security” (July 27, 2026); StorageReview, alliance launch analysis (July 29, 2026); Linux Foundation, “Open Models and Open Weights Are Foundational to Secure AI” (July 2026)
- The Hacker News, “TrapDoor Supply Chain Attack Spreads Credential-Stealing Malware via npm, PyPI, and CratesIO” (May 25, 2026); cyberpress.org, “Supply Chain Attack Compromises 34 Packages Across npm, PyPI, Crates” (May 2026)
- infosecurity-magazine.com, “TeamPCP Targets Telnyx Package in Latest PyPI Software Supply Chain Attack” (March 27, 2026); Unit 42, “Weaponizing the Protectors: TeamPCP’s Multi-Stage Supply Chain Attack on Security Infrastructure” (March 31, 2026)
- OX Security, “The Mother of All AI Supply Chains: Critical, Systemic Vulnerability at the Core of Anthropic’s MCP” (April 15, 2026); Infosecurity Magazine, “Systemic Flaw in MCP Protocol Could Expose 150 Million Downloads” (April 16, 2026); Computing UK, “Flaw in Anthropic’s MCP Putting 200k Servers at Risk” (April 17, 2026)
- Wiz, “The Security Risks Hiding Behind Exposed MCP Servers” (July 28, 2026); Trend Micro, “Update on Exposed MCP Servers: The Threat Widens to the Cloud” (April 28, 2026)
- Unit 42, “Chinese-Speaking Threat Actor Harnesses AI Models for Autonomous Cyberattacks” (July 30, 2026); Help Net Security, “Chinese hacker used DeepSeek to launch autonomous cyberattacks on vulnerable servers” (August 3, 2026); Security Affairs, “Cybercriminals Are Leveraging Autonomous AI Offensive Security Agents” (July 31, 2026); forkast.news, “DeepSeek Became the Attack Engine Because It Had the Fewest Guardrails” (August 1, 2026)
- Microsoft, “When prompts become shells: RCE vulnerabilities in AI agent frameworks” (May 7, 2026); sqmagazine.co.uk, “Google Unveils Gemma 4 12B

With On Device AI Features” (June 4, 2026); Trend Micro, “Fault Lines in the AI Ecosystem: State of AI Security Report” (March 3, 2026)

- SHIELD-AI Monthly Deep Review, August 2026 (v1.4 to v1.5); SHIELD-AI Sandbox Escape Gap Analysis v1.5 (INC-19..INC-25, G14-G19)

SHIELD-AI – Watchlist Report, edition of August 3, 2026 Rebuilt and replaced each monthly deep review; the repo copy is always current. Authored by the Security Architecture Practice